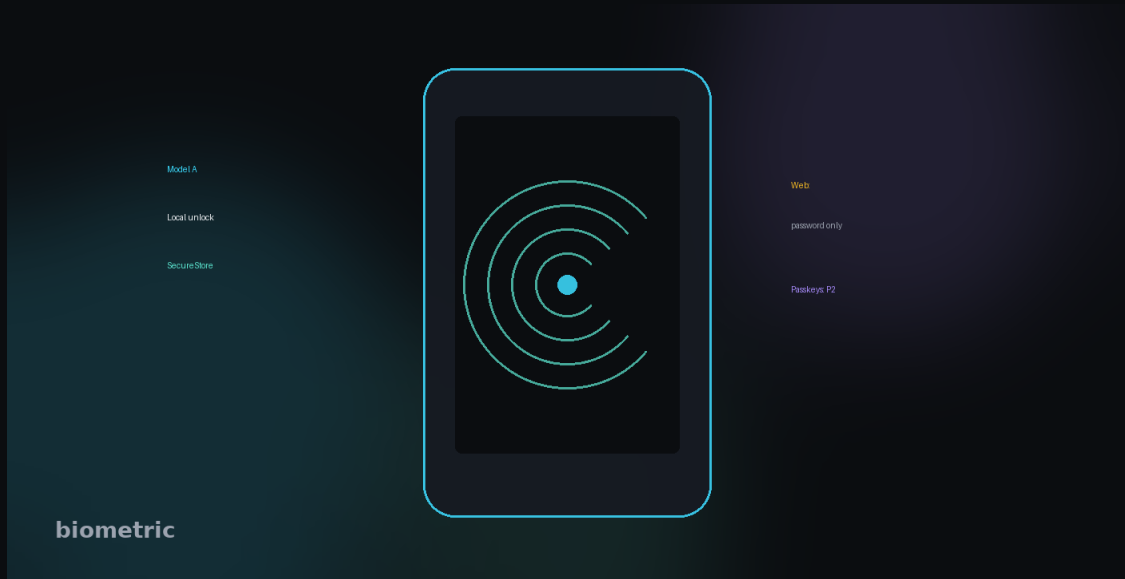




# Biometric Sign-In — Research + Plan Digest

Dark visual edition • 2026-09-24

Card t\_c880a23a • AUTH • Research digest (no app implementation)

**Chuck Broaddus / Kelyra • Confidential**

Source: dated research digests under notes/company • graphics illustrate locked recommendations.

## Executive recommendation

### Locked recommendation

Model A: local biometric unlock of a SecureStore-held Supabase session (expo-local-authentication + expo-secure-store). Web/Chromebook stay password-only in P0. Passkeys are P2. Student biometric default off. Never upload face templates to Kelyra.

## Decision cards

|                                      |                                 |
|--------------------------------------|---------------------------------|
| <b>Model</b><br><br>A · local unlock | <b>Store</b><br><br>SecureStore |
| <b>Web</b><br><br>Password only      | <b>Passkeys</b><br><br>P2       |

### Model A — local biometric unlock (not face upload)

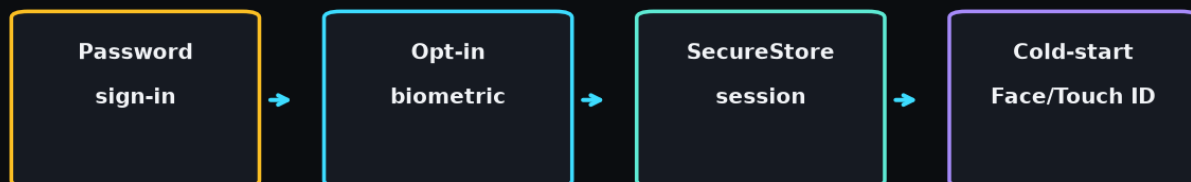


Figure: Model A unlock flow.

# Biometric Sign-In — Research + Plan Digest (BIOAUTH-R1 / P1)

Date: 2026-09-24 Author: Chief of Staff / Grok Bot (Kelyra) Status: Ready for Chuck review SoT pair: [notes/company/biometric-signin-research.md](#) · [notes/company/biometric-signin-plan.md](#)  
Card: [t\\_c880a23a](#) Access date for citations: 2026-09-24 (America/Chicago)

This dated file is a readable pack for Chuck. Full detail lives in the SoT pair above. Research + plan only — no app implementation.

## Top recommendations (P0–P2)

### P0 (do first — native unlock MVP)

- 1. P0-1/2 — Add `expo-local-authentication` + `expo-secure-store`; move/gate Supabase session off plain AsyncStorage into SecureStore.
- 2. P0-3/4 — Opt-in after password sign-in; cold-start Face ID / Touch ID / Android strong biometric before app chrome.
- 3. P0-5 — Android unlock uses `biometricsSecurityLevel: 'strong'` (Class 3).
- 4. P0-6/7 — Sign-out wipes gated tokens; web/Chromebook: no biometric UI.
- 5. P0-8/9 — Chrome seat switch is not biometric; v1 = one remembered account.

### P1

- Idle re-lock (Capture / Ride), shared-device warnings, student default off, biometry-change recovery, real-device QA matrix.

### P2

- Supabase experimental passkeys (web first), Credential Manager initial Android sign-in, multi-account biometric switcher.

## Research (digest)

### Verdict

Ship Model A: biometric unlock of a locally stored Supabase session — not password replay, not “upload face to Kelyra.” Templates stay in Secure Enclave / TEE. Kelyra today persists auth in AsyncStorage (`src/lib/supabase/client.ts`) with no biometric modules installed — that is the gap.

### Platforms

| Platform | Capability                                                       | Expo bridge                                   |
|----------|------------------------------------------------------------------|-----------------------------------------------|
| iOS      | Face ID / Touch ID / Optic ID via LocalAuthentication + Keychain | <code>expo-local-authentication</code> + e... |
| Android  | BiometricPrompt; Class 3 strong vs Class 2 weak                  | Same modules; prefer strong for token unlock  |
| Web      | No Face ID module path                                           | Password P0; passkeys P2                      |

### Expo + Supabase approach

- 1. Password (existing `signInWithPassword`) once.
- 2. Opt-in → store session in SecureStore with `requireAuthentication`.
- 3. Cold start → authenticate → `setSession` / refresh → existing `AuthProvider`.
- 4. Never store password.
- 5. Passkeys (`registerPasskey` / `signInWithPasskey`) are a later primary factor, not P0.

Kelyra change list (summary)

Dependencies + app.json plugins/permissions → EAS/dev client → SecureStore auth storage → lock state in AuthProvider → splash/Settings UX → logout wipe → web hide → (P1) idle lock / student policy → (P2) passkeys.

Security / privacy

- Biometrics on-device only.

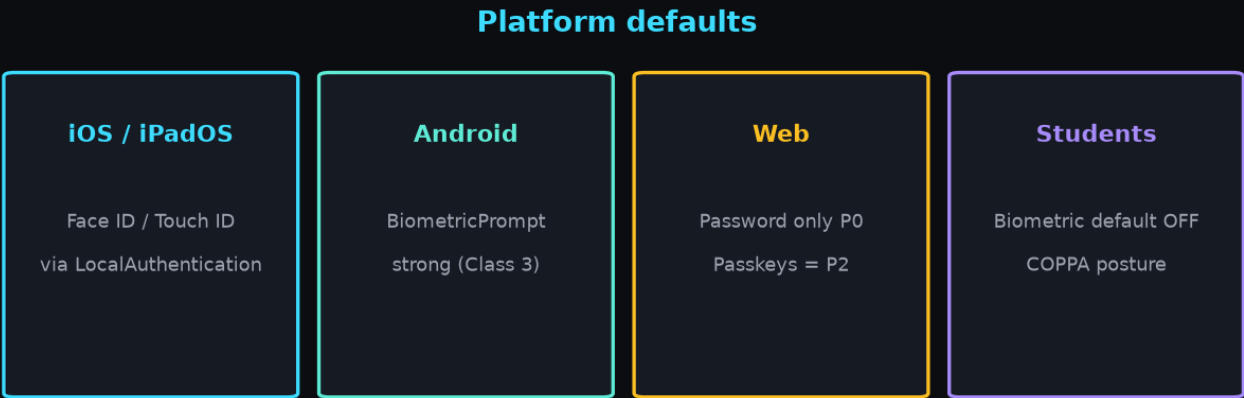


Figure: Platform and hat defaults.

- FERPA: unlock controls device possession of an already-authorized session; RLS/hats unchanged.
- COPPA / students: default biometric off.
- Shared family iPad: show which account unlocks; warn that enrolled face unlocks that session.
- MDM may disable biometrics → password always works.
- Refuse: password-in-keychain replay; cloud face login; required biometrics with no fallback.

UX defaults

| Hat                       | P0 default                    |
|---------------------------|-------------------------------|
| Teacher / office / parent | Offer opt-in; cold-start gate |
| Student                   | Off                           |
| Web                       | Password only                 |

Plan (digest)

Product law

Biometric unlock ≠ new identity provider. Password always available. Seat switch ≠ re-auth. Passkeys deferred.

Phased table

| Phase | IDs           | Theme                                                                                                |
|-------|---------------|------------------------------------------------------------------------------------------------------|
| P0    | P0-1 ... P0-9 | Native opt-in unlock, SecureStore, strong Android, web hide, logout hygiene, seat/multi-account laws |

| Phase | IDs           | Theme                                                                                 |
|-------|---------------|---------------------------------------------------------------------------------------|
| P1    | P1-1 ... P1-6 | Idle lock, shared-device, student policy, invalidation UX, refresh hygiene, device QA |
| P2    | P2-1 ... P2-4 | Passkeys, Credential Manager, multi-account                                           |

Open questions for Chuck

- 1. Student biometric: off / office / parent?
- 2. Idle re-lock in first Eng send?
- 3. Full SecureStore migration vs layered gate?
- 4. Passkeys vs OAuth priority?
- 5. Shared iPad: warn vs block?

Citations (accessed 2026-09-24 America/Chicago)

- 1. <https://docs.expo.dev/versions/v57.0.0/sdk/local-authentication/>
- 2. <https://docs.expo.dev/versions/latest/sdk/securestore/>
- 3. <https://docs.expo.dev/guides/using-supabase/>
- 4. <https://developer.apple.com/documentation/localauthentication>
- 5. <https://developer.apple.com/documentation/localauthentication/accessing-keychain-items-with-face-id-or-touch-id>
- 6. <https://developer.apple.com/documentation/bundleresources/information-property-list/nsfaceidusedescription>
- 7. <https://developer.android.com/identity/sign-in/biometric-auth> (docs page last updated 2026-09-16 UTC)
- 8. <https://developer.android.com/reference/androidx/biometric/BiometricManager.Authenticators>

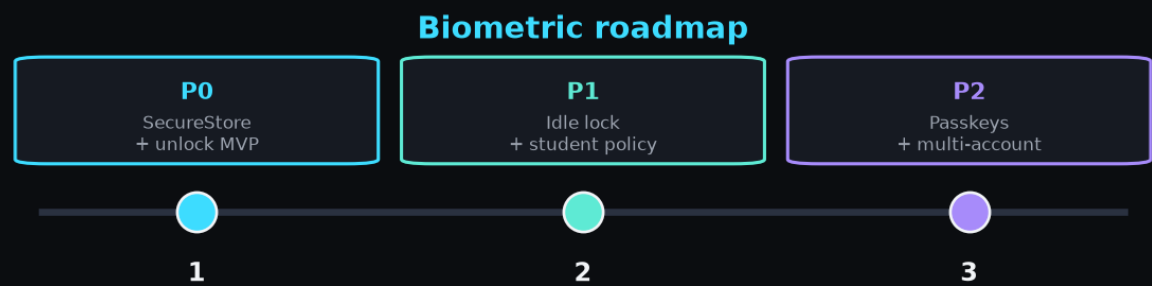


Figure: P0 → P1 → P2 roadmap.

- 9. <https://source.android.com/docs/security/features/biometric>
- 10. <https://supabase.com/docs/guides/auth/passkeys>
- 11. <https://supabase.com/docs/reference/javascript/auth-signinwithpasskey>
- 12. <https://supabase.com/docs/reference/javascript/auth-registerpasskey>

Full SoT embeds

Detail below mirrors the company SoT pair for offline reading. If they diverge later, company files win.

# Biometric Sign-In Research Note (BIOAUTH-R1)

Date: 2026-09-24 Author: Chief of Staff / Grok Bot (Kelyra) Status: Ready for Chuck review Revision: R1 (greenfield research; no prior BIOAUTH note) Cards: `t_c880a23a` Access date for all URLs below: 2026-09-24 (America/Chicago)

Related (do not conflate): Google / Apple OAuth (separate); office password reset (`resetLoginPassword`); chrome seat / hat switch (`src/lib/chrome/seat.ts` — not JWT); FERPA posture in `avg-spec-security-ferpa.md` / `docs/architecture.md`. Grounded in live code: Expo `^57`, `@supabase/supabase-js` `^2.57.4`, session via `AsyncStorage` in `src/lib/supabase/client.ts`, splash auth (`SplashLanding` / `sign-in.tsx`), `AuthProvider` + `signInWithPassword`. No `expo-local-authentication` or `expo-secure-store` in `package.json` / `app.json` today. Constraints for this card: Research + plan only. No app code, no SQL, no Hermes AI staffing, no force-push.

## Executive summary

CEO wants fast re-auth on phone (Face ID / Touch ID / Android biometrics) for teachers (capture, car-line), office, parents, and students — without turning Kelyra into a password-less identity provider that phones home with face/fingerprint data.

Verdict: Ship biometric unlock of a locally stored Supabase session (refresh token) as the P0 product, not “biometric as primary cloud factor.” Templates never leave the Secure Enclave / TEE. Expo SDK 57 already has first-party modules (`expo-local-authentication`, `expo-secure-store`). Kelyra’s gap is storage + gate UX: sessions live in `AsyncStorage` today (readable without biometrics). Web / Chromebook stays password (or later passkeys); native Face ID needs a dev/prod client, not Expo Go.

Copy: Apple `LocalAuthentication` + `Keychain` gating; Android `BiometricPrompt` Class 3 (`BIOMETRIC_STRONG`); Expo `LocalAuthentication` + `SecureStore` `requireAuthentication`; opt-in after successful password sign-in; fallback to password/handle. Skip: Storing the password in `SecureStore`; sending biometrics to Supabase; every-launch biometric with no opt-in; treating chrome seat switch as a biometric event; building a student Face ID requirement on shared classroom iPads in v1.

## 1. What “biometric sign-in” actually means

Three architectures are commonly confused:

| Model                                          | What happens                                                                                                      | Server sees                 | Fit for Kelyra                                                                        |
|------------------------------------------------|-------------------------------------------------------------------------------------------------------------------|-----------------------------|---------------------------------------------------------------------------------------|
| A. Local biometric unlock of session           | After password/SSO once, device stores refresh session; Face ID/Touch ID/fingerprint unlocks access to that se... | Normal Supabase JWT refresh | Recommended P0                                                                        |
| B. Password replay after biometric             | App stores password; biometric reveals it and calls <code>signInWithPassword...</code>                            | Password again              | Refuse — expands breach surface for zero benefit                                      |
| C. Cloud biometric / passkey as primary factor | <code>WebAuthn</code> / passkey registered with Supabase; assertion proves possession                             | Public key + assertion      | P2 (Supabase passkeys exist, experimental; web-first; native mobile needs extra glue) |

Apple and Android both emphasize that biometric templates stay on-device. The app receives only pass/fail (or a `Keystore/Keychain` unlock). Kelyra must never invent a “upload face for login” path.

## 2. Platform capabilities

### 2.1 Apple — `LocalAuthentication`, Face ID, Touch ID, Optic ID

- Framework: LocalAuthentication (LAContext). Policies: biometrics-only vs biometrics-or-device-passcode.
- Biometry types include Face ID, Touch ID, and (visionOS / supported devices) Optic ID — all evaluated by the Secure Enclave; app never receives template data.
- NSFaceIDUsageDescription required in Info.plist for Face ID; without it Face ID is blocked / falls back. Touch ID historically has no parallel usage string.
- Pattern for sessions: protect Keychain items so reads require Face ID / Touch ID (Security + LocalAuthentication).

Sources: Local Authentication; Accessing Keychain Items with Face ID or Touch ID; NSFaceIDUsageDescription. Accessed 2026-09-24 (America/Chicago).

2.2 Android — BiometricPrompt / BiometricManager

- Use AndroidX Biometric (BiometricPrompt), not deprecated FingerprintManager.
- Authenticator classes (CDD): Class 3 / BIOMETRIC\_STRONG (fingerprint, iris, or 3D face meeting strong requirements — eligible for Keystore crypto); Class 2 / BIOMETRIC\_WEAK (e.g. some camera face unlock — BiometricPrompt OK, not Keystore ops); Class 1 convenience (lockscreen only).
- Apps declare allowed authenticators (BIOMETRIC\_STRONG, BIOMETRIC\_WEAK, DEVICE\_CREDENTIAL). Credential Manager is preferred for initial sign-in; BiometricPrompt for re-auth.
- Google guidance last updated 2026-09-16 UTC (shown on page).

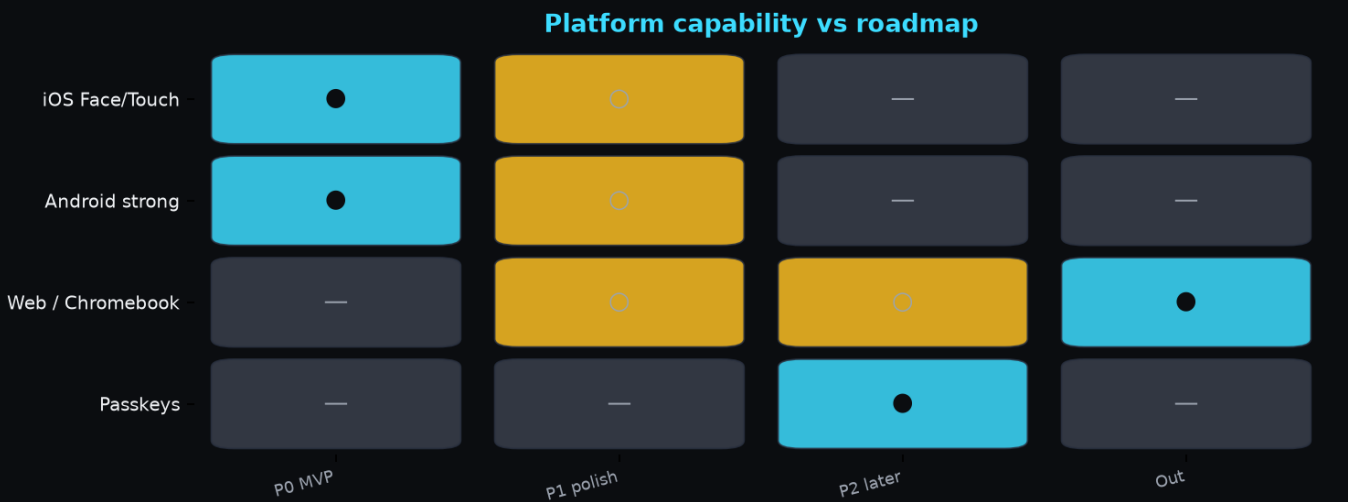


Figure: Capability matrix (illustrative).

Sources: Show a biometric authentication dialog; BiometricManager.Authenticators; AOSP Biometrics. Accessed 2026-09-24 (America/Chicago).

2.3 Expo / React Native modules (SDK 57 — matches Kelyra)

| Module                    | Role                                           | Notes for Kelyra                                                      |
|---------------------------|------------------------------------------------|-----------------------------------------------------------------------|
| expo-local-authentication | Prompt Face ID / Touch ID / Android biometrics | hasHardwareAsync, isEnrolledA...                                      |
| expo-secure-store         | Keychain / Keystore KV                         | requireAuthentication: true gates reads; keys invalidated when bio... |
| Neither installed today   | —                                              | Both need npx expo install + config plugins + new native binary...    |

| Module  | Role                                                 | Notes for Kelyra                                                                                                        |
|---------|------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|
| Expo Go | Face ID / <code>requireAuthentication</code> limited | Face ID not supported in Expo Go; SecureStore biometric option incomplete without <code>NSFaceIDUsageDescript...</code> |

Sources: Expo LocalAuthentication (v57); Expo SecureStore; Using Supabase (Expo). Accessed 2026-09-24 (America/Chicago).

2.4 Web / PWA / Chromebook

- No Face ID / Touch ID API equivalent in Expo web today for this product law.
- Browser WebAuthn / passkeys can use platform authenticators (Windows Hello, ChromeOS, some Android Chrome) — separate from `expo-local-authentication`.
- Kelyra web should keep handle + password (and existing flows) for P0; treat passkeys as P2.

3. Auth architecture with Supabase (Expo)

3.1 Current Kelyra posture

Session persists via AsyncStorage with `autoRefreshToken` / `persistSession` in `src/lib/supabase/client.ts`. Cold start can restore a full signed-in app without biometrics. Sign-in is `signInWithPassword`. Chrome seat preference is separate AsyncStorage (`kelyra.chrome.seat.<profileId>`) — UI only.

3.2 Recommended architecture (Model A)

Password/SSO once → opt-in → SecureStore session with `requireAuthentication` → cold start LocalAuthentication → refresh/setSession → AuthProvider. Never store password. On biometry change, gated secrets become unreadable → full sign-in. Sign-out wipes secrets.

3.3 Passkeys / WebAuthn (Model C — later)

Supabase experimental passkeys: enable in Auth settings; `registerPasskey` / `signInWithPasskey`. Complements local Face ID unlock; does not replace P0.

3.4 Remember device vs every-launch gate

Recommend opt-in then cold-start gate on iOS/Android; idle gate P1; web unchanged.

4–10. Remaining research sections

See SoT file for full Kelyra change table, security/privacy, UX tables, needed vs desired, open questions, and citation list (same URLs as above).

BIOAUTH-P1: Biometric unlock plan

Date: 2026-09-24 Status: Spec / plan only — no app code.

Product law

| Surface          | Job                                        | Not                                |
|------------------|--------------------------------------------|------------------------------------|
| Biometric unlock | Gate this device’s stored Supabase session | Cloud face login; password storage |
| Password         | Always fallback; web P0 path               | Removed when biometrics on         |
| Chrome seat      | Tray after unlock                          | Biometric step                     |
| Passkeys         | Later primary factor                       | P0                                 |

## Roadmap

P0: deps, SecureStore session, opt-in, cold-start unlock, Android strong, logout wipe, web hide, seat/multi-account laws. P1: idle re-lock, shared-device warning, student off, biometry-change UX, AppState refresh, device QA. P2: passkeys web → native, Credential Manager, multi-account.

## Non-goals

No password-in-SecureStore; no biometric upload; no required biometrics without fallback; no Expo Go Face ID SoT; no seat-switch biometric; no silent opt-in; no weak Android for token access; no student default on; no SQL for P0.

## Next

Chuck review → optional Eng ticket with P0 checklist only (not this card).

Meta · Card t\_c880a23a (AUTH) · Dark visual edition 2026-09-24 · Not legal advice where privacy/compliance topics appear · No Hermes staffing.